

Cloud Security Audit Report

Prepared by: Hrishikesh Jadhav
Tanishka Chitnis
Engagement Type: Independent Cloud Security Assessment (Self-Initiated Lab)
Cloud Provider: Amazon Web Services (AWS)
Account Scope: Single AWS Account. Personal Sandbox (Account ID 966042699310)
Assessment Tool: Prowler v5.33.0 (open-source AWS CIS/compliance scanner)
Report Date: July 2026
Classification: Internal / Portfolio Demonstration (Hypothetical client data)

1. Executive Summary

This report documents a self-directed cloud security assessment performed on a deliberately misconfigured AWS sandbox environment. This sandbox consists of a social media web application hosted on EC2 . The application stores user images on a S3 bucket. The objective was to demonstrate the full audit life cycle:

1. baseline scan
2. risk-rated findings
3. remediation
4. re-validation scan.

Metric	Before Remediation	After Remediation
Prowler ThreatScore	46.98%	96.11%

2. Scope of Audit

In scope:

Identity:	Identity Access Management
Network	Virtual Private Cloud (VPC)
Compute	Amazon EC2 (Elastic Compute Cloud)
Storage	S3
Logging & Monitoring	CloudTrail/logging configuration, CloudWatch alarming

Out of scope:

- Third-party integrations,
- Multi-account/Organizations posture (single account only),
- Production workloads (none present)

3. Methodology

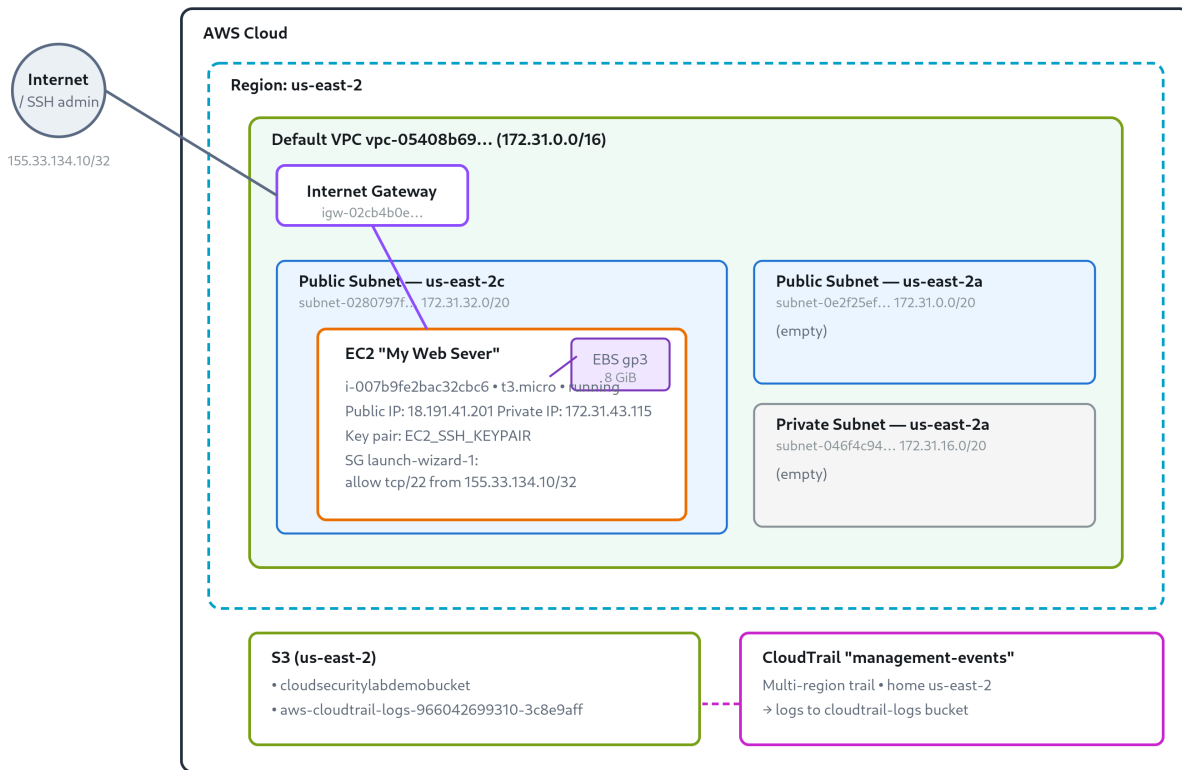
Risk Analysis Matrix. Each finding is rated using a Likelihood × Impact model, consistent with standard GRC practice:

Likelihood ↓ / Impact →	Low	Medium	High
High	Medium	High	Critical

After

AWS Architecture — Account 966042699310

Region: us-east-2 (Ohio) • Identity: IAM user "auditor" • Generated 2026-07-08



Key components:

- 1 VPC (vpc-05408b69a53452fe4) spanning us-east-2 , with one public and one private subnet
- 1 EC2 instance behind security group launch-wizard-1 (originally all-ports-open)
- 1 S3 bucket (cloudsecuritylabdemobucket)
- 2 IAM users: tara (developer), auditor (Prowler scan identity)
- CloudTrail trail management-events (multi-region)

6. Data Flow

Users connect to the EC2-hosted social media app over HTTPS. The instance sits in the VPC's public subnet. The application reads and writes user-uploaded images directly to the S3 bucket.

7. Findings

Sr. No	Observation	Severity	Risk	Recommendation	Status	Revalidation Observation
1	User <code>tara</code> had the AWS-managed AdministratorAccess policy directly attached. Per walkthrough, <code>tara</code> is a developer and does not require admin-level access.	High	This gives excessive permission to the account in question and could have critical impact in instance of account compromise.	Remove AdministratorAccess grant only the required permissions for the developer role.	Remediated	Administrative permissions for the user <code>tara</code> were removed.
2	The AWS root user account did not have MFA enabled.	Critical	Without MFA on the Root account, a password compromise could lead to compromise of organization's cloud assets.	Enable MFA (hardware key or authenticator) on the root account immediately; avoid routine use of root entirely.	Remediated	Multifactor authentication through google authenticator was enabled.
3	Security group <code>launch-wizard-1</code> (<code>sg-0cfd42f420d5530f</code>) allowed inbound traffic on all ports from 0.0.0.0/0	High	Unrestricted access to all ports from all origins could create a risk of service on the instance getting compromised. And this may lead to compromise of credentials and related resources to that EC2 instance.	Restrict ingress to only required ports and known-good source IPs (least privilege at the network layer) never use 0.0.0.0/0 for administrative ports.	Remediated	Security groups were restricted to TCP/22 from a single trusted IP.
4	S3 bucket <code>cloudsecuritylabdemobucket</code> did not have Block Public Access (BPA) enabled .	Critical	Giving Public access to a bucket with user PII data will cause information and client confidentiality breach .	Enable all four BPA settings at the bucket . And use aws presigned urls to access resources on the S3 bucket.	Remediated	Block public access was disabled for the S3 bucket <code>cloudsecuritylabdemobucket</code>

Sr. No	Observation	Severity	Risk	Recommendation	Status	Revalidation Observation
5	No CloudTrail trail with logging enabled was found in the region reviewed.	Critical	Since there is no logging in place, having no logging implemented will help threat actors operate without being detected.	Enable a multi-region CloudTrail trail with log file validation and deliver logs to a dedicated, access-controlled S3 bucket.	Remediated	Multi-region trail with log file validation was enabled.
6	EC2 metadata service does not have IMDSv2 at the account default level.	High	In instances where if the web application in EC2 has a SSRF vulnerability, the threat actor could fetch the the IMDS meta data which contains critical information like IAM credentials.	Enforce IMDSv2 as the account-wide default (http-tokens: required) for all current and future instances.	Open	
7	S3 bucket did not have MFA Delete enabled.	High	Considering the weakness in the other factors of this account(weak password policy, admin access to accounts and no logging), the likelihood of S3 bucket deletion by a threat actor increases drastically. Additionally, since the bucket contains customer PII data, loss of this data would be bad for the organization.	Enable MFA Delete on buckets holding data of any sensitivity.	Remediated.	MFA Delete was enabled for the S3 bucket.

Sr. No	Observation	Severity	Risk	Recommendation	Status	Revalidation Observation
8	S3 bucket policy did not enforce HTTPS-only (TLS) access.	Medium	Without the implementation of https, data being transferred to and from the bucket will be in plain text and may result in Man in the middle attack.	Add a bucket policy statement denying requests where <code>aws:SecureTransport</code> is <code>false</code> .	Remediated.	Bucket policy was attached for the S3 bucket with Effect": "Deny", Bool": { "aws:SecureTransport": "false" }.
9	VPC contained only public subnets and no private subnet segmentation existed.	Medium	Without a private sub-net the database of the web application will also be inside a public sub-net and this could expose the database to public internet and hence creating a new attack surface and possibility of data ex filtration.	Introduce private subnets for resources that don't require inbound internet access; route via NAT for outbound-only needs.	Remediated	
10	IAM account password policy did not meet CIS baseline (length, complexity, reuse, expiration).	Medium	A weak password policy could make IAM users with weak passwords vulnerable to attacks like credential stuffing.	Enforce ≥14 character minimum, upper/lower/number/symbol complexity, 24-password reuse prevention, and a defined expiration window.	Remediated	IAM policy with the following was configured: 1. 14-char minimum 2. Full complexity 3. 24-password reuse prevention 4. 90-day expiration configured.
11	No CloudWatch Logs metric filters/alarms exist for security-relevant CloudTrail events (unauthorized API calls, console sign-in without MFA, root account usage, IAM policy changes, security group/NACL/route table/gateway changes, S3 bucket policy changes, CMK deletion, Organizations changes).	Medium	No monitoring and alerts could lead to unauthorized events not getting detected.	Implement the CIS-recommended metric filter + alarm set on the CloudTrail log group (13 filters); route to an SNS topic or equivalent for real-time notification.	Open	

9. Appendix

- Full Prowler finding export: 445 checks evaluated, final pass rate 96.11%.
- Screenshots referenced: provider setup, scan execution, findings detail views, compliance framework scoring (CIS 1.4–8.0, NIST CSF, PCI DSS, ISO 27001, SOC2, and others — 47 frameworks scored automatically by Prowler).
- Tool: Prowler v5.33.0, AWS provider, account 966042699310.